

CodeAtlas 码鉴：证据驱动的 AI 代码审查与项目体检工作台

AI WEB 网页开发挑战赛 · 技术文档 · 2026 年 9 月 · v1.0.0 · 公开仓库 github.com/aabbcc070403/codeatlas
· 技术栈 Next.js 15 + React 19 + TypeScript (strict) + PostgreSQL/pgvector + 独立 Node worker

CodeAtlas 码鉴面向高校学生与缺少专职审查人员的小型前端团队：用户上传 ZIP 代码包，系统先运行确定性的静态规则体检，再在严格预算与工具约束下进行 AI 定向审查，最终把每一条问题连同可点击核验的路径、行号与引文证据呈现出来，并支持受限追问（可附界面截图，多模态）、单文件补丁提案、三格式报告导出与快照对比。

本文档按赛题要求组织：项目概述 → 需求分析 → 系统架构设计 → AI 技术方案（选型理由 / 集成方式 / 优化策略） → 核心功能实现 → 测试与部署 → 创新点说明 → 总结与展望。文中所有评测数字均来自仓库内记录的真实命令运行，可按评测记录 ID 与 scanId 回溯；AI 结果如实标注运行环境（真实模型 DeepSeek 两轮 / Mock 受控管线），多套数字分栏并存、互不覆盖。

核心功能 F01-F12 + 多模态追问 规格范围全落地并扩展	自动化测试 344 项全绿 单元 204 · 集成 131 · E2E 9
真实评测（v2 提示词） P 0.857 / R 1.000 llm_no_rag, holdout, n=3 均值	向量检索实证 29/29 hybrid pgvector+词法 RRF 真实生效

1. 项目概述

1.1 问题背景：三类工具都回答不了「证据在哪」

学生与初级团队在课程设计、竞赛项目和首个 Web 产品中反复遇到同一困境：ESLint 类规则工具只报模式命中、不解释业务影响；通用大模型对话可以「看着像专家」，却会编造不存在的代码行；付费代码审查 SaaS 面向企业仓库与流水线，对一个 6 文件的课程作业既贵又重。更关键的是——三者都回答不了评审和答辩现场最致命的问题：「你这条结论的证据在哪一行？」

1.2 产品的回答：确定性打底，AI 定向，证据收口

CodeAtlas 用三层结构回答这个问题：确定性静态规则提供零幻觉的基线命中；受预算约束的 AI 定向审查在有限步工具循环里读真实代码、检索项目规范；证据校验门把所有 AI 结论收口——每条引文必须逐字符匹配当前快照的真实行段，匹配失败即丢弃并计入统计，绝不静默放行。产品全

程诚实标注：静态命中、AI 推断、Mock 与真实模型使用不同标签，「未再检出」不等于「已验证修复」。

2. 需求分析

2.1 目标用户与典型场景

目标用户：完成课程设计 / 毕业设计 / 竞赛项目的高校学生，以及 1-5 人的前端小团队。他们有真实代码、有提交期限，但没有专职安全或审查人员。

- **用户故事 1（提交前自查）：**作为毕设学生，我希望在答辩前知道代码里还有哪些会被评审追问的问题，并能当场指出证据行号，避免现场被问住。
- **用户故事 2（学习型审查）：**作为课程学习者，我希望每个问题都附带规范来源与修复建议，让我理解「为什么是问题」而不只是「哪里报了红」。
- **用户故事 3（修复可验证）：**作为项目维护者，我希望修复后重新扫描，明确区分「未再检出」和「已验证修复」，并导出报告作为提交材料。

2.2 功能需求（F01-F12 与扩展）

编号	功能	需求要点
F01	项目与导入	ZIP 导入（路径穿越 / 炸弹 / 符号链接防护）、快照历史、文件树、只读代码预览
F02	结构体检	文件统计、语言分布、依赖概览、忽略明细、相对导入关系
F03	静态规则	≥6 条确定性 AST 规则（交付 9 条），候选标 needs_review
F04	AI 审查	风险优先抽样 + 受限工具循环，输出带路径 / 行号 / 引文，全部经证据校验
F05	专属 RAG	预置版本化规范 + 自有 Markdown 导入；向量 + 词法双路 RRF 融合检索
F06	证据工作台	筛选、行号定位、来源 / 触发条件 / 影响 / 修复建议、确认 / 误报反馈
F07	受限追问	围绕问题与快照的追问（预算硬限），无终端 / 联网 / 写文件工具； 可附 ≤3 张界面截图（多模态）
F08	补丁提案	单问题单文件 diff，校验旧文本 / 哈希 / 脱敏区间 / 语法不退化，下载 .patch 不写原件
F09	报告导出	JSON / Markdown / 可打印 HTML，与界面同源
F10	快照对比	新增 / 仍存在 / 未再检出 / 不可比较四类变化，「未再检出 ≠ 已验证修复」
F11	评测中心	24 样例数据集、三模式消融、P/R/F1 / 证据有效率可回溯到 scanId
F12	演示保障	访问码两级、会话隔离、任务取消、租约恢复、TTL 清理、日 token 预算

2.3 非功能需求

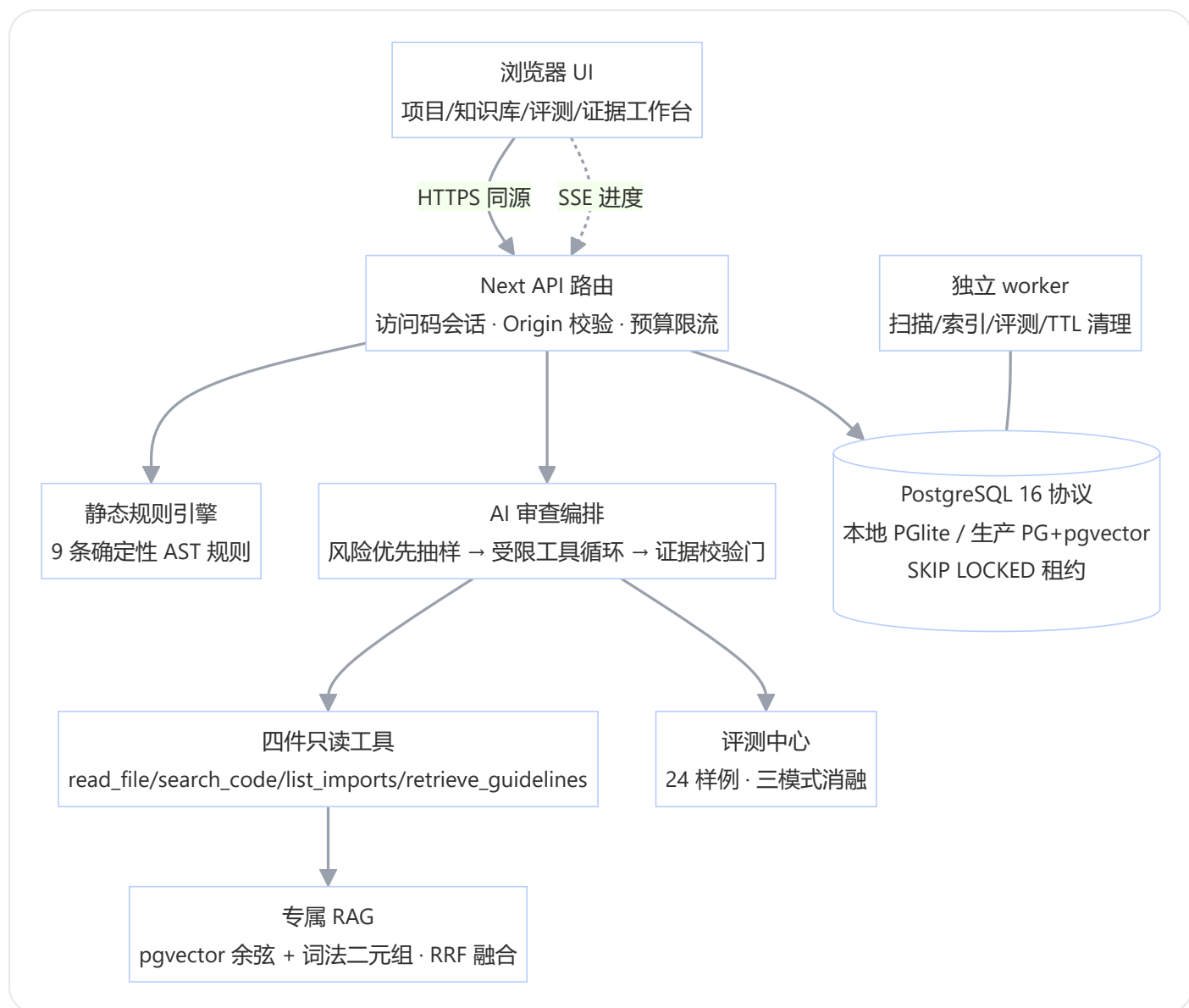
- **安全**：不执行上传内容；敏感文件拒绝收录；密钥等长脱敏；跨会话一律 404；AI 只读四件工具。
- **可控与诚实**：单扫描 / 追问 / 补丁各有预算硬限；Mock 与真实模型标签隔离；无效引文计入统计不美化。
- **性能**：首屏可交互 < 1s（本机实测 FCP $\leq$ 188ms）；SSE 实时进度、断线可恢复。
- **可复现**：评测数据集内容哈希版本化；测试基线封闭（不受开发机环境污染）；全部数字带口径标注。

3. 系统架构设计

3.1 技术栈与运行形态

前端 Next.js 15（App Router）+ React 19 + TypeScript strict + Tailwind CSS；数据层 Drizzle ORM + PostgreSQL 16 协议——本地用嵌入式 PGLite（pgvector 扩展，自实现 Postgres 线协议 socket 服务）零依赖启动，生产用 PostgreSQL + pgvector，同一 SQL 合同。异步任务由独立 Node worker 处理，作业表 `FOR UPDATE SKIP LOCKED` 租约领取，不引入 Redis。AI 调用统一走 AI SDK（OpenAI 兼容接口）。

3.2 总体模块与数据流



3.3 关键机制

- 六阶段扫描管线**：ingest → index → static → ai → validate → report；阶段推进与终态写入均在租约事务内确认（失租不能写结果）；崩溃恢复从持久化 stage 续跑。
- 实时进度**：SSE 每 15 秒心跳、浏览器断线重连、无 SSE 时每 2 秒轮询降级；刷新页面不丢任务。
- 同构数据层**：PGLite 与生产 PostgreSQL 使用同一迁移与 SQL 合同，集成测试可通过 `INTEGRATION_DATABASE_URL` 直连真实 PostgreSQL。
- 安全边界**：导入拒绝路径穿越 / 绝对路径 / 符号链接 / 保留设备名，按流式解压字节限额；疑似密钥在持久化、向量化、发送云端前等长遮盖；命中脱敏区间的补丁禁止导出。

3.4 关键工程决策（实测支撑）

- **作业租约而非消息队列**：作业表 + SKIP LOCKED 实现了双 worker 竞争、失租接管、取消落实，可被集成测试确定性覆盖（租约 / 恢复类测试 9 项）。
- **评测数据集内容哈希版本化**：`datasetVersion = v<revision>-<hash8>`，生成器幂等（两次运行字节一致），标注 ↔ 规则输出双向校验，失败即中止生成。
- **测试语料数据文件化**：脱敏样例、规则样例、评测样例统一存 JSON 数据文件（被测功能的输入数据），源码内零危险字面量，安全审计与测试真实性两全。

4. AI 技术方案

4.1 技术选型理由

- **大模型接入**：选择 OpenAI 兼容 Chat Completions（实测 DeepSeek `deepseek-chat`）而不是绑定单一厂商 SDK——学生可用免费 / 低成本额度完成课程级审查，换供应商只改环境变量。对话 / 补丁 / 追问共用同一接入面。
- **Agent 编排**：自研受限工具循环（而非 LangChain 等通用框架）——本产品对「可控」的要求高于「灵活」：工具白名单四件只读、每轮调用次数 / token / 墙钟三重预算、证据校验收口，这些硬约束用一个小状态机表达比用框架钩子更可审计。**Agent 具备规划、工具调用、自主决策**：风险优先抽样决定看什么文件，循环内自主决定读哪行 / 检索什么规范 / 何时提交结论。
- **RAG 架构**：pgvector 余弦 Top10 + 字符二元组词法 Top10 的 RRF 融合，而不是纯向量——规范文本短、术语密集（「jsx key」「@ts-ignore」），词法对精确符号名召回稳定，向量补语义相近，RRF 免调权。项目自有 Markdown 可导入形成专属知识库。
- **嵌入模型**：本地 `bge-small-zh-v1.5`（transformers.js + ONNX/WASM，512 维）而不是云 embedding API——零成本、可离线复现、不占日额度；向量维度随模型可变（迁移已解耦列维度）。云 embedding 同样支持（换配置即可）。
- **多模态**：追问支持图像附件（截图 + 代码证据 + 规范三源融合），走同一 OpenAI 兼容面的 vision 消息格式；VL 模型可插拔（GLM-4V / GPT-4o / Qwen-VL）。
- **AI 安全与可控性**：证据校验门（引文逐字符匹配真实行段 + 读取覆盖检查 + 规范 chunk 白名单）、日额度原子预留账本、脱敏先行、提示注入防线（代码 / 注释 / 用户问题中的指令一律视为待审数据）。
- **工具集成**：Function Calling（submit_findings / submit_answer 结构化提交 + 四件只读工具），全部参数服务端 Zod 校验；无终端、联网、写文件能力。

4.2 集成方式

- **统一调用包装** (callModelWithBudget) : 调用前按「输入估算 + 输出上限」原子预留日额度、收缩 maxOutputTokens、合并单请求超时与整体墙钟 (取更短者) ; 结算实测优先, 失败只释放预留; 重试计入请求上限。审查 / 追问 / 补丁三条链路共用同一合同。
- **结构化输出**: 结论必须经 `submit_findings` / `submit_answer` 工具提交 (JSON Schema 约束), 杜绝自由文本解析歧义。
- **多模态消息**: 图像以 data URL image part 进入消息序列, 按固定 token 计入预算 (1,100/张, 避免 base64 长度折算高估百倍) ; 服务端只存元数据不存原图。
- **RAG 检索工具**: `retrieve_guidelines` 返回规范 chunk (含 chunkId) , 引用白名单 = 本轮实际返回集合, 检索不到就答「证据不足」。

4.3 优化策略 (实测驱动)

- **提示词 v1 → v2 (主效应)** : v1 允许「不确定时降低 confidence 提交」, 实测对照项目误报 7–11 条/次 (P 0.396–0.421) ; v2 改为「宁缺毋滥: 无确凿证据不提交, 空结论是正常结果」, FP 压到 0–4 条/次, **P 升至 0.756–0.857, Recall 跨 9 次运行全部 1.000**。同一模型、同一数据集、只改提示词的对照实验, 记录见 6.2 与 `deliverables/real-embedding-ablation-2026-09-23.md` 。
- **风险优先抽样**: 静态命中文件 → 其直接依赖 → 路径序补足至 30 个, 把有限的模型注意力花在最可能有问题的文件上。
- **预算参数化**: 追问默认 4 次模型 / 8 次工具 / 60s (防滥用) , 复杂问题可经 `AI_ASK_MAX_MODEL_CALLS` / `AI_ASK_MAX_TOOL_CALLS` / `AI_ASK_WALL_MS` 放宽——实测提示词收紧后默认预算已够用 (v2 全部运行零预算耗尽) 。
- **图像 token 固定估算与本地嵌入免计费**: 成本模型可预期, 学生用量近乎零成本。

4.4 证据校验: 可信性的核心

所有 AI 引文必须来自当前脱敏快照的真实行段 (统一 LF 后逐字符匹配 + 完整读取覆盖检查) ; 规范引用只接受本轮检索返回的 chunkId 白名单; 无效候选至多 1 次结构修复, 仍无效则丢弃并计入 `invalidCitations` 与 FP 统计——**不通过丢弃结果美化指标**。修复轮重交按身份跨轮去重, 同一候选不重复计数。

4.5 受限追问与多模态截图

追问围绕当前 finding 与快照, 四件只读工具 + 同一证据校验; 证据不足明确返回 `insufficient_evidence` , 不编造调用链 / 测试结果 / 规范条款。用户可附 ≤3 张界面截图

(png/jpeg/webp/gif, 单张 ≤1MB) : 截图作为图像 part 与代码证据、规范检索结果在同一上下文中融合, 用于理解界面 / 交互类问题; 截图不参与文本脱敏 (界面明示), 原图不落库。

4.6 可审阅补丁

单问题单文件 diff 提案: 校验旧文本匹配、基线哈希、脱敏区间拒绝、语法不退化 (新旧诊断签名级比较, 「错误数量没增加」不等于无新增错误); 只可下载 .patch, 永不写入原件。

4.7 预算与限流

单扫描 12 次模型 / 30 次工具 / 6 万输入 + 8 千输出 token / 180 秒; 追问 4 / 8 / 60s (可配置); 补丁 2 次 / 60 秒; 全局日额度原子预留 (调用前 reserve、结算 settle、失败 release, 跨日记账绑定预留凭据幂等); 访问码失败限流每 IP 每 10 分钟 10 次。

5. 核心功能实现

5.1 端到端使用流程

访问码进入工作台 → 新建项目 → 上传 ZIP (导入报告列出收录 / 忽略 / 脱敏明细) → 启动审查 (可选云端 AI) → SSE 进度 (六阶段) → 证据工作台浏览问题 (点击引用定位代码行) → 追问 (可贴截图) → 补丁提案 (下载 .patch) → 报告导出 (JSON / Markdown / 可打印 HTML) → 修复后二次扫描 → 快照对比四态 (新增 / 仍存在 / 未再检出 / 不可比较)。评测中心 (admin) 可发起三模式评测并逐行回溯。

5.2 关键实现要点

- **证据工作台**: 每条问题展示来源标签 (static / ai / combined)、证据状态 (valid / needs_review)、触发条件、影响、修复建议; 引用点击定位 + 行段高亮, 定位失败显示「证据无效 / 待核查」不高亮误导。
- **快照对比语义**: AI 覆盖按「实际读取行段完整覆盖」判定, 行号漂移或覆盖不足一律「不可比较」, 杜绝把「没看到」当「已修复」。
- **评测回溯**: 每个指标聚合自逐项目 scanId, 评测页「查看」直达原始扫描; 无效引文单列并计入 FP。
- **多模态追问 UI**: Ctrl+V 粘贴 / 按钮选图、缩略图预览与移除、超限与格式错误就地提示; 历史消息展示「附 N 张截图 (原图未持久化)」。

6. 测试与部署

6.1 测试策略：三层全绿

单元 204 项（规则 / 脱敏 / 预算 / 指标手算表 / 对比语义 / 语料契约）+ **集成 131 项**（真实库上的导入 / 扫描 / 追问 / 补丁 / 报告 / 租约恢复 / 日额度账本 / 评测台账）+ **E2E 9 项**（生产构建 + 独立 web/worker/DB 的全流程闭环、移动端无溢出、UI 回归），共 **344 项全绿**（2026-09-23）。TypeScript strict 全量 + ESLint 零警告；测试基线封闭（额度与 Mock 基线钉死，不受开发机 .env 污染）。

6.2 评测方法与实测结果

数据集：24 个 TS/JS 样例项目（12 缺陷 + 12 相近对照，6 类问题），16/8 划分、内容哈希版本 v1-cd06ca6f；标注 ↔ 规则输出双向校验。**三模式**：static_only（纯规则）/ llm_no_rag（AI 无检索，消融对照）/ hybrid_rag（AI + 双路 RRF 检索）。指标：一对一匹配 P/R/F1、证据有效率；无效引文计入 FP。**口径声明**：24 样例小样本结果只说明检测管线在本数据集上的行为，不能推广为真实项目准确率。

运行口径	模式	Precision	Recall	F1	说明
Mock 管线 (09-13, Mock)	static_only	1.000	1.000	1.000	真实静态规则结果
	llm / hybrid	1.000	1.000	1.000	受控 Mock 验证管线行为，非模型能力
真实模型提示词 v1 (09-19, DeepSeek)	llm_no_rag	0.396	1.000	0.566	holdout n=3 均值；FP 集中于对照项目误报
	hybrid_rag (词法降级)	0.421	1.000	0.591	
真实模型提示词 v2 (09-23, DeepSeek + 本地嵌入)	llm_no_rag	0.857	1.000	0.923	n=3 零方差；FP 1 条/次
	hybrid_rag (词法对照)	0.786	1.000	0.912	范围 0.750–0.857
	hybrid_rag (向量+词法 RRF)	0.756	1.000	0.850	范围 0.600–1.000；检索 29/29 hybrid

如实结论：① 提示词 v2 是精度主效应（FP 7–11 → 0–4 条/次，Recall 不受损）；② 向量检索路已真实闭环（29/29 次 retrieve_guidelines 为 hybrid，此前唯一未验证项），RAG 对 P/F1 的影响在 n=8 方差内，**不宣称显著提升**——RAG 的稳定增量在规范引用证据与可解释性；③ 规格目标（hybrid P ≥ 0.80 / R ≥ 0.65）：R 稳定达标，P 均值贴近目标线。全部运行可按评测记录 ID / scanId 回溯（deliverables/real-ai-*.md、real-embedding-ablation-2026-09-23.md）。

6.3 前端性能实测

生产构建路由级代码分割：First Load JS 102–136 kB（最重工作台页 136 kB）；`next start` 生产服务 + Chromium 1440×900 冷加载：/login TTFB 30ms / DCL 44ms / **FCP 188ms**，首页 FCP 56ms（本机 loopback 口径，反映渲染与包体开销）。移动端 390px 无横向溢出由 E2E 断言覆盖。详见 `deliverables/frontend-perf-and-ai-ux-2026-09-23.md`。

6.4 部署

本地：PGlite socket（`pnpm db:dev`）+ 迁移 / seed + `pnpm dev` + worker，无需 Docker。**生产**：Compose 三服务（pgvector/pg16 + web + worker，同一镜像不同 command），多阶段构建、非 root、fixtures 随镜像分发、生产强制环境变量注入密钥与访问码、HTTPS 反代前置（cookie Secure）。集成测试支持 `INTEGRATION_DATABASE_URL` 直连真实 PostgreSQL（逐测试文件独立临时库）。如实声明：Docker / Compose 与生产 PostgreSQL 路径已实现并经人工审阅，本机无 Docker 未实测，属首次部署验证项。

7. 创新点说明

7.1 技术创新点

- **证据校验门（Evidence Gate）**：AI 结论的每条引文必须逐字符匹配当前脱敏快照真实行段 + 读取覆盖检查 + 规范 chunk 白名单，三层收口；无效即丢弃并计数。把「AI 说了什么」与「可核验证据」在架构层解耦。
- **确定性评测口径**：内容哈希版本化数据集 + 标注↔规则双向校验 + 一对一贪心匹配 + 无效引文计入 FP（不美化），指标可回溯到每次扫描的 scanId——学生项目也能给出可复核的评测。
- **本地嵌入 + 双路 RRF 的零成本 RAG**：ONNX 本地 bge 嵌入（512 维，列维度解耦迁移）+ pgvector 余弦 + 词法二元组 RRF 融合，整条检索链零 API 成本、可离线复现，并给出「向量路真实生效」的 29/29 调用级实证。
- **统一预算账本**：审查 / 追问 / 补丁 / 嵌入共用「调用前原子预留、结算实测优先、失败幂等释放、跨日绑定凭据」的日额度账本 + 三重单次预算（次数 / token / 墙钟），在学生可用的免费额度内做到成本可预期。

7.2 应用创新点

- **证据工作台交互**：问题 → 引文点击 → 代码行高亮定位 → 规范来源展示的闭环，「证据在哪」从答辩难题变成一次点击。
- **诚实的快照对比语义**：「未再检出 ≠ 已验证修复」四态区分（覆盖不足一律不可比较），把修复验证做成产品语义而非口号。

- **可审阅补丁提案**：不写原件、语法不退化校验（诊断签名级比较）、脱敏区间拒绝导出——「AI 建议改什么」以人可审的 diff 交付。
- **多模态截图追问**：界面截图 + 代码证据 + 规范检索三源融合的追问体验，前端 UI 类问题可以「贴图发问」；原图不落库的隐私取向。

7.3 与既有方案的差异

维度	ESLint / 静态规则	通用大模型对话	企业级审查 SaaS	CodeAtlas
证据可核验	规则命中行	常编造行号	较好	引文硬校验 + 读取覆盖
业务解释 / 规范来源	无	有但无出处	部分	专属 RAG 规范引用可回溯
成本与门槛	免费	按 token	企业定价 / 流水线	学生预算可用，本地嵌入零成本
修复验证语义	无	无	部分	四态对比 + 补丁提案
诚实标注	—	弱	中	Mock/真实/来源全隔离

7.4 社会价值与商业潜力

社会价值：把「证据可核验的审查能力」从企业工具箱带到高校场景，帮助学生在答辩与评审前自查自证，降低初次工程实践的质量风险；教学上可作为「AI 可信性」课程案例（证据校验、预算控制、诚实评测都是可讲可复现的方法论）；促进负责任 AI 的实践——产品自身就是「AI 结论必须带证据」的示范。

商业潜力：目标市场为高校课程 / 竞赛 / 毕设群体与初创前端团队。可持续模式三层：① 教育版 SaaS（按席位 / 按月订阅，含专属规范库）；② 院校采购（私有化部署 + 教学案例包，本仓库 Docker Compose 即交付形态）；③ 增值服务（竞赛冲刺体检报告、团队规范定制）。成本侧本地嵌入 + 预算硬限使毛利结构可预期；开源核心 + 云端增值是开发者工具的成熟路径。

8. 总结与展望

8.1 总结

- 交付 F01-F12 全部核心功能并扩展多模态截图追问；344 项自动化测试全绿（单元 204 / 集成 131 / E2E 9），TypeScript strict + ESLint 零警告。
- 真实模型两轮评测 + 三路 RAG 消融全部完成且可回溯；提示词优化使 Precision 从 0.396-0.421 提升到 0.756-0.857，Recall 跨 9 次运行全部 1.000；向量检索 29/29 真实生效。
- 首屏 FCP ≤ 188ms、First Load JS ≤ 136 kB；安全边界（不执行上传、脱敏、证据校验、预算、会话隔离）逐条有测试或探针支撑。

8.2 局限 (如实)

- 评测为 24 样例小样本口径，不能外推真实项目准确率；RAG 对指标的提升在该样本上方差内。
- 多模态图像内容理解需 VL 模型（当前实测模型为纯文本，截图流程与预算链路已就绪并如实标注）； Docker / Compose 与生产 PostgreSQL 路径待首次部署实测。
- 静态规则目前覆盖 TS/JS/JSX/Vue 六类问题；语法不退化校验基于诊断签名比较，不替代完整类型检查。

8.3 展望

- **MCP 工具集成**：以 Model Context Protocol 暴露审查 / 检索工具，接入 IDE 与协作 Agent。
- **端云协同**：浏览器端 Transformers.js 推理 (WebGPU) 承担轻量初筛，云端承担深审，进一步降本。
- **评测扩容与更强模型对照**：更多语言 / 规模的真实项目 holdout，模型侧精度扩展实验。
- **团队协作**：问题认领、误报反馈回流规则库、规范库团队共享。

参考与来源

- `docs/architecture.md` —— 模块图、数据流、安全边界、关键合同
- `docs/evaluation.md` (§4 / §4.5 / §4.6) —— 数据集、三模式、Mock 与真实模型分栏数字
- `deliverables/real-ai-holdout-2026-09-19.md` / `real-embedding-ablation-2026-09-23.md` —— 逐次评测记录 ID 与结论
- `deliverables/frontend-perf-and-ai-ux-2026-09-23.md` —— 性能实测与 AI 交互体验核验
- `docs/demo-script.md` —— 5-8 分钟演示脚本 (标注 Mock 环节与真实数字来源)